

[doc. web n. 9946386]
Provision of September 28, 2023
Register of Provisions
No. 424 of September 28, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Secretary General Fabio Mattei;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing
"Code regarding the protection of personal data,
containing provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC" (hereinafter
"Code");

HAVING REGARD to Regulation No. 1/2019 concerning
internal procedures of external relevance,
aimed at carrying out the tasks and
exercising the powers assigned to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web
No. 9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD to the documentation in the records;

HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Guarantor's
Regulation No. 1/2000;

Reporter Prof. Pasquale Stanzione;

PREMISED

1. The reported incident
In the month of XX, this Authority received a
report alleging a violation
of the regulations concerning the protection of personal data
in relation to the presence, in the premises
of the former Sanatorio Guido Banti, located in Pratolino and
pertaining to the Azienda USL Toscana Centro (hereinafter
the Company), of health documentation (e.g., prescriptions,

medical records, and X-rays) in a state of abandonment and accessible to anyone (video documentation acquired in the records).

A similar report had been submitted to the Office in the month of XX, regarding which the preliminary investigation was closed as, based on what was stated in the records by the aforementioned Company, a complaint had been filed with the competent authorities and the withdrawal of the aforementioned documentation, pertaining to clinical episodes that occurred over 20 years prior, had been ordered on XX.

2. The investigative and procedural activity

Also with reference to the incident reported in XX, the Office of the Guarantor initiated a preliminary investigation in order to gather any useful elements of evaluation regarding the current presence of health documentation in a state of abandonment in the aforementioned premises of the former Sanatorio Banti and whether it is the same documentation on which the Authority had already opened the aforementioned investigation of XX (notes of XX, prot. No. XX and of XX, prot. No. XX).

In the notes of XX and XX, the aforementioned Company represented, in particular, that:

“the structure, although unused, is not in a state of abandonment, as too lightly described by those who enter the building, in an absolutely unauthorized and unallowable manner, (against whom, in the past, complaints/denunciations/warnings have been filed with the Competent Authority (...)) considering the risks to physical safety for anyone approaching the aforementioned structure”;

“Access from the outside is possible through a main gate located along the first brick wall, always locked with a chain and padlocks; the availability of access keys is, exclusively, in the hands of the structure and security responsables. Furthermore, access within the first perimeter is also allowed for the personnel of a private security agency that monitors the area pertaining to the structure, with periodic rounds in the morning and at night, with a fixed presence on-site during the afternoon hours. The second gate and the main door are accessible only to company personnel”;

“it cannot be ruled out that in some areas there may have been, inadvertently left by the personnel responsible for the relocation, some documents or X-rays, as seems to be shown in the videos indicated by the same Guarantor Authority in the request for information”;

“the violation of the premises occurred by some individuals overcoming and/or forcing the first and second level of protection, also at the risk of their own

lives”;

“During accesses by authorized personnel equipped with high levels of personal protection carried out in previous years, some remaining X-rays and other documents were collected, all predominantly illegible (those that were found to be legible have been transferred to the company archives). It cannot be excluded that the evidence reported in the aforementioned videos could have been deliberately brought into the structure with the aim of attributing to the company responsibility or otherwise a mismanagement of the...”

“information heritage of the same”;

“therefore, the possible presence of unstructured and unorganized documentation, let alone preserved according to ordinary standards but nonetheless protected from access, given the absence of specific regulatory obligations for preservation in this regard, and considering the outdated nature of the contents, can be qualified on one hand as a tomb-like mode of storage”;

“any voluntary exfiltration, entirely illegitimate and episodic, of documentation from the site in question, considering the outdated nature of the contents and the unlikely readability of the same, could still prove to be entirely irrelevant to the rights of the interested parties”;

“In terms of information security, it is represented that the non-ideal methods of preservation concern documents that are not among those subject to infinite preservation obligations, such as, for example, is the case for the more well-structured, albeit paper-based, clinical file”;

“The documentation presented in the video indicated by the Authority is placed in areas that are not accessible or safely reachable, mostly consisting of paper documents without evidence regarding personal data. The information that may be readable does not allow for the direct identification of the interested parties, and is obviously no longer current, with potential impacts on the interested parties being absolutely modest.”

On XX, the Office recorded the occurrence of the verification that, as indicated in the report, by accessing the webpage “https://...”, it was possible to view a video titled “XX” (published on XX within the YouTube channel named “XX” (XX) and that by accessing the webpage “https://...” it was possible to view another video titled “XX” (published on XX within the aforementioned YouTube channel named “XX” (XX). The aforementioned videos have been acquired into the records in electronic format.

In relation to the reported incident and taking into account what emerged in the preliminary phase of the initiated investigation, the Office, with act prot. no. XX, of XX, notified the Azienda Usl Toscana Centro, pursuant to art. 166, paragraph 5 of the Code, of the initiation of the procedure for the adoption of the measures referred to in article 58, paragraph 2 of the Regulation, contesting, for the incorrect methods of preservation of health documentation in the aforementioned premises, the violation of articles 5, paragraph 1, letters a), e), and f) and 32 of the Regulation, of article 75 of the Code with reference to the specific sector regulations (Legislative Decree 22/01/2004, no. 42) and inviting the aforementioned Company to produce to the Authority defensive writings or documents or to request to be heard by the Authority (art. 166, paragraphs 6 and 7, of the Code; as well as art. 18, paragraph 1, of Law no. 689 of 24/11/1981).

By note of XX, the Company requested to be heard and sent its defensive memoranda in which it represented, in particular, that in the month of XX a verification “in-depth of all the premises of the former Sanatorio Guido Banti regarding the possible presence of health documentation, as well as to proceed with its removal and possible management according to company procedures” was carried out - by a specialized company. According to what was indicated by the aforementioned Company, “The documentation collected by the company, precisely gathered in 11 bags of material, of domestic use and modest capacity as they are bags used by staff for easy transport within the structure, later transformed into 4 urban bags, was subjected to analysis and subsequent disposal procedure.”

With reference to the activities of XX, the Company specified that “it has carried out an inspection at

the facility and has commissioned a moving company to carry out the activity of handling and moving archives, should they have been found on site.” “Therefore, it is conceivable that, in some areas (highly unsafe and difficult to access), some documents or X-rays may have been inadvertently left behind, as seems to be shown in the videos indicated by the same Authority in the information request of XX.”

The Company also represented that “the contested documentation, even if it had been adequately preserved by the Company, is nonetheless dated to about thirty years ago. According to the regulations and the consequent company retention schedule, the documentation relating to X-rays has a retention limit of a maximum of 10 years. During this period, no exercise of rights regarding a request for access or copy of health documentation has been received by the Company, with respect to which it would have promptly activated within the terms provided by the regulations.” “Moreover, although they may be defined as X-rays, it should be specified that their clinical effectiveness, in relation to the time they were performed, is now exhausted. The time elapsed beyond the maximum retention period cannot be considered suitable to determine a negative impact on the interested parties since, over time, an X-ray, besides no longer being representative of health conditions, is compromised in its integrity, thus no longer functional for a correct diagnosis and therefore no longer useful to the person. Furthermore, at the time of the closure of the facility's activities, that is, in 1989, the regulations regarding preservation were less stringent than those currently in place, also in view of the introduction of the GDPR which has further raised awareness regarding the aspect of preservation.”

On XX, the hearing of the aforementioned
illegittima dei dati personali e dalla loro accessibilità non autorizzata” (art. 32, par. 1 del Regolamento).

4. Conclusioni

In conclusione, si evidenzia che l'Azienda deve garantire il rispetto della normativa sulla protezione dei dati personali, adottando misure adeguate per la conservazione e il trattamento dei dati, in particolare quelli di natura sanitaria. È fondamentale che l'Azienda proceda con la massima attenzione nella gestione dei documenti rinvenuti, assicurando che eventuali dati personali siano trattati in conformità con le disposizioni di legge vigenti e che siano adottate tutte le misure necessarie per prevenire accessi non autorizzati e garantire la sicurezza dei dati.

5. Raccomandazioni

Si raccomanda all'Azienda di:

1. Implementare un piano di gestione dei dati che preveda procedure chiare per la conservazione e il trattamento dei documenti, in particolare quelli contenenti dati personali.
2. Formare il personale coinvolto nella gestione dei dati sulla normativa vigente in materia di protezione dei dati personali.
3. Effettuare una valutazione dei rischi associati al trattamento dei dati e adottare misure tecniche e organizzative adeguate per mitigare tali rischi.
4. Monitorare regolarmente le procedure di gestione dei dati per garantire la conformità alle normative e l'efficacia delle misure adottate.

6. Prossimi passi

Si suggerisce di programmare un incontro con le parti interessate per discutere le misure da adottare e garantire un approccio coordinato nella gestione dei dati rinvenuti. È essenziale che l'Azienda agisca tempestivamente per garantire la protezione dei dati e la sicurezza delle informazioni, in attesa della vendita dell'ex Sanatorio Banti.

from access, whether accidental or illegal, to personal data transmitted, stored, or otherwise processed” (art. 32 of the Regulation). The data controller must also ensure compliance with the aforementioned principles and be able to demonstrate it (“accountability principle”) (art. 5, par. 2, of the Regulation). As highlighted in Recital 39 of the Regulation, compliance with the aforementioned principles entails the obligation for the data controller to ensure that the retention period for personal data is limited to what is necessary, ensuring compliance with this time limit through periodic review. In this regard, it is emphasized that “processing” includes any operation or set of operations performed on personal data or sets of personal data, including “data retention” (art. 4, par. 1, n. 2, of the

Regulation). It is noted that in accordance with the aforementioned principle of data retention limitation, personal data may be retained in a form that allows for the identification of data subjects for no longer than is necessary to achieve the purposes for which they are processed.

With reference to the specific case, the sector regulations identify specific retention periods that healthcare facilities must comply with concerning the type of medical documentation in their possession (see, among others, circular from the Ministry of Health dated December 19, 1986, n. 900; art. 5 of the Ministerial Decree of February 18, 1982; art. 4 of the Ministerial Decree of February 14, 1997; Ministerial Decree of August 3, 2001; Legislative Decree n. 200/2007; D.P.R. 445/2000; Legislative Decree 42/2004; Legislative Decree 82/2005; Legislative Decree 502/1992).

Where there is no specific legal provision identifying the retention periods for a document containing personal data, it is the responsibility of the data controller to determine, in compliance with the aforementioned principles, an appropriate retention period for achieving the legitimately pursued purposes, which must also be indicated in the information provided to the data subject pursuant to art. 13 of the Regulation.

In this matter, it is further noted that the Code of Cultural Heritage and Landscape (Legislative Decree 22/01/2004, n. 42) provides specific and stringent limits for the consultation of documents in archives (arts. 122 et seq.). The archival regulations mentioned above make a significant distinction between current archives, deposit archives, and historical archives, delegating to the State, regions, and other local public entities the regulation of access for historical purposes to current archives based on the guidelines of the Ministry of Cultural Heritage (art. 124, Legislative Decree 22/01/2004, n. 42).

By virtue of this regulatory framework, the Tuscany Region (the Region where the aforementioned Company is located) has adopted specific regulations for the retention and access of documents in archives, establishing standardized rules and procedures (Director's Decree 4448 of October 28, 2013; Director's Decree 4084 of September 14, 2015; Director's Decree 1785 of February 13, 2019; Director's Decree 4084 of September 14, 2015; Director's Decree 1785 of February 13, 2019; Resolution 1229 of December 22, 2014).

In this regard, the archival and bibliographic supervision of the Tuscany Region has developed a document titled "Selection and Disposal of Documents in Healthcare Companies," which specifies the retention periods for various medical documents held by healthcare facilities ("Disposal Guidelines for ASLs").

On this point, it is noted that the aforementioned Company, with a resolution from the General Director dated December 23, 2019, adopted the "Company Regulation for Document Retention – Disposal Guidelines," within which the document "Selection and Disposal of Documents in Healthcare Companies" mentioned above was included. In the aforementioned regulation, the cited Company states that: "The documents and archives of the A.S.L., like the documents of all public entities, are considered cultural assets and must therefore be preserved in accordance with current legislation (Legislative Decree 42 of January 22, 2004, and subsequent amendments); "For preservation obligations, it is also meant to preserve the documentation from deterioration, removal, tampering, and forgery"; "The retention of documents must be organized and carried out in such a way that they can be retrieved and exhibited with extreme ease and timeliness."

The aforementioned regulation specifies the methods and procedures for the disposal and definitive elimination of documents of the same Company and the responsibilities of the General Affairs SOC in this regard.

In light of the aforementioned regulatory framework, it is highlighted that the Company's assertion regarding "the absence of specific legal obligations for retention" contradicts the regulations on the obligations for the retention and disposal of medical documentation identified by the aforementioned legislation, which are also reported in the same company regulation on "document retention – Disposal Guidelines."

Furthermore, the assertion that the retention of medical documentation in the premises of the former

Banti Sanatorium, in the manner visible in the aforementioned videos and not denied by the Company, can be qualified as “a tomb-like storage method” is not acceptable, given the specific procedures provided for the disposal of archives as stipulated by the sector regulations and the aforementioned company regulation.

It is also noted that the abandonment of medical documentation, which should have been retained within the times and according to the methods indicated in the aforementioned regulation, is also in contrast with the aforementioned principles of integrity and

****Data Privacy, as well as Lawfulness, Fairness, and Transparency, and Limitation of Storage as per Article 5 of the Regulation.****

It cannot be considered acceptable to assert that "The information that may be readable does not allow for the direct identification of the data subjects," given that in some images in the records, the personal data of the data subjects are visible. Similarly, it is not possible to exclude, as instead done by the aforementioned Company, that the removal or damage of such documentation—considering also its age—could cause harm to the subject to whom it refers, even in relation to the potential impossibility of exercising the rights recognized to them (e.g., request for access or copy of health documentation) and regardless of the fact that—at present—the Company has not received such requests.

Furthermore, the reference to the circumstance that "at the time of the cessation of the activity of the structure, namely in 1989, the regulations regarding storage were less stringent than those currently in place, also in view of the introduction of the GDPR which has further raised awareness regarding the aspect of storage," is not shareable, as highlighted above, since the specific sector regulations already provided indications at that time regarding the correct methods of storing health documentation.

****4. Conclusions.****

In light of the above evaluations, taking into account the statements made by the data controller during the investigation—and considering that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor"—the elements provided by the data controller in the defense memoranda do not allow for overcoming the observations notified by the Office with the initiation of the procedure, nor do any of the cases provided for by Article 11 of the Guarantor Regulation No. 1/2019 apply.

In this context, considering what is represented in the records and the videos produced by the notifier, and acknowledging the activities of emptying the health documentation from the premises of the former Banti Sanatorium carried out by the Company in XX and the more specific activities carried out in XX, as well as the adoption of the prescribed document disposal procedures, it is noted that the aforementioned health documentation has been stored in a manner inconsistent with those indicated in the aforementioned sector regulations and in the same company regulation adopted in this matter and, therefore, in violation of Articles 5, paragraph 1, letters a), e), and f) and 32 of the Regulation, and Article 75 of the Code with reference to the specific sector regulations (Legislative Decree 22/01/2004, No. 42).

In this framework, while the Company has declared that it has removed the aforementioned health documentation from the premises of the former Banti Sanatorium and has proceeded with the prescribed document disposal procedures, the conditions for the adoption of corrective measures under Article 58, paragraph 2, of the Regulation do not exist.

****5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code).****

The violation of Articles 5, paragraph 1, letters a), e), and f) and 32 of the Regulation, and Article 75 of the Code, caused by the omission of the Company Usl Toscana Centro, is subject to the application of the administrative pecuniary sanction, pursuant to Article 83, paragraphs 4 and 5 of the Regulation.

The Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] measures [corrective] provided for in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case," and, in this context, "the College [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Guarantor Regulation No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 83, paragraph 2 of the Regulation; therefore, it is observed that:

1. The processing carried out is of particular gravity, as it involved personal data related to health status concerning health services, even if provided about twenty/thirty years ago, and contained in the health documentation (only partially readable) present—in a state of abandonment—in the premises of the former Banti Sanatorium (Article 89, paragraph 2, letters a) and g) of the Regulation);
2. The Authority became aware of the aforementioned violation from a report (Article 83, paragraph 2, letter h) of the Regulation);
3. The Company fully cooperated with the Authority during the investigation and the present procedure (Article 83, paragraph 2, letter f) of the Regulation);
4. The Company has previous heterogeneous violations.
with respect to the processing of data in question (art. 83, par. 2, lett. e) of the Regulation);
5. the Company has commissioned a specialized firm to remove the aforementioned health documentation from the premises of the former Sanatorio Banti, which is in a state of structural disrepair and evident degradation (art. 83, par. 2, lett. c) of the Regulation);
6. the Company, despite not complying with the principles related to the lawfulness of processing, data retention limitation, and data integrity and confidentiality (arts. 5, par. 1, lett. a), e) and f) and 32 of the Regulation), as well as the specific sector regulations on the retention of health documentation (art. 75 of the Code), had provided for armed surveillance of the aforementioned premises and had made multiple reports to the judicial authority regarding the illegal access to the aforementioned premises (art. 83, par. 2, lett. b) and c) of the Regulation);

In light of the aforementioned elements, assessed in their entirety, it is deemed appropriate to determine the amount of the administrative fine provided for by art. 83, par. 4 and 5, lett. a) of the Regulation, in the amount of € 50,000.00 (fifty thousand) for the violation of arts. 5, par. 1, lett. a), e) and f) and 32 of the Regulation and art. 75 of the Code, as an administrative pecuniary sanction deemed, pursuant to art. 83, par. 1 and 3, of the Regulation, effective, proportionate, and deterrent.

It is also considered that the accessory sanction of publication on the website of the Authority of this provision should be applied, as provided for by art. 166, comma 7 of the Code and art. 16 of the Regulation of the Authority n. 1/2019, also considering the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in art. 17 of Regulation n. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

ALL OF THE ABOVE, THE AUTHORITY

declares the unlawfulness of the processing of personal data carried out by the Azienda UsI Toscana centro, for the violation of arts. 5, par. 1, lett. a), e) and f) and 32 of the Regulation and art. 75 of the Code as stated in the reasoning.

ORDERS

pursuant to arts. 58, par. 2, lett. i) and 83 of the Regulation, as well as art. 166 of the Code, the Azienda Usl Toscana centro, with legal headquarters at Piazza Santa Maria Nuova n. 1 – 50142 Florence (Tax code/VAT number 06593810481), to pay the sum of € 50,000.00 (fifty thousand) as an administrative pecuniary sanction for the violations indicated in this provision. It is noted that the offender, pursuant to art. 166, comma 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

REQUIRES

the Azienda Usl Toscana centro to pay the sum of € 50,000.00 (fifty thousand), according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to art. 27 of law n. 689/1981;

DISPOSES

pursuant to art. 166, comma 7 of the Code, the full publication of this provision on the website of the Authority and considers that the conditions referred to in art. 17 of Regulation n. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

Pursuant to art. 78 of the Regulation, arts. 152 of the Code and 10 of Legislative Decree n. 150/2011, against this provision it is possible to appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, September 28, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Stanzione

THE SECRETARY GENERAL

Mattei